Strong authentication and privileged access — Keycloak

Crédit Océane (fictif) · Keycloak — royaume oceane (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-12 13:13**

Auditor sign-off: **pending**
Run: **20261112-130651-keycloak-bench-meta**

Owner: **IT department — IAM team**

1. Executive summary

OPINION AT TESTING

Satisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-12 13:13, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**0** findings	**0** findings closed and verified	**0** open findings
0 human approvals	**116** sensitive data items masked in evidence	**2 min 24 s** audit duration	**$0.109 *** measured AI cost

Key messages

- No findings: every tested control is compliant.

2. Scope and method

Engagement	AUD-2026-KC-01
Entity	Crédit Océane (fictif)
System	Keycloak — royaume oceane (fournisseur d'identité)
System criticality	Supports critical or important functions (DORA)
Environment	Test Keycloak (fictitious realm)
Owner	IT department — IAM team
Lead auditor	Attest CI (automated run, no human auditor)
Date	2026-11-12 13:13
Framework	DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4
Audited target	Keycloak (open-source identity provider), through the read-only gateway
Work programme	existing catalogue reused · controls/AUD-2026-KC-01.en.json

In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-12; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	STATUS	DUE DATE
–	PSI-4.1	MFA enforced for privileged administrator accounts	Critical	Compliant		
–	PSI-4.2	MFA enforced for users of critical system	High	Compliant		
–	PSI-4.3	Strong password policy with length and complexity	Medium	Compliant		
–	PSI-4.4	Account lockout after repeated login failures	Medium	Compliant		
–	PSI-4.5	Idle session timeout limited to 15 minutes	Medium	Compliant		
–	PSI-4.6	Logging of administration actions	High	Compliant		
–	PSI-4.7	No generic or shared administrator accounts	High	Compliant		

4. Detailed findings and controls

PSI-4.1 MFA enforced for privileged administrator accounts

Critical · Compliant

Compliant control — Every account holding the realm role admin has multi-factor authentication configured. · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `[]`



At testing — The screenshot corroborates the test. All eight listed admin accounts show MFA (OTP configured) as yes. · 8/8 sensitive data items masked
`2026-11-12 13:13:54 · SHA-256 473f168ba6fbe17c…`

PSI-4.2 MFA enforced for users of critical system

High · Compliant

Compliant control — Every user account in the realm, which supports critical or important functions, has multi-factor authentication configured. · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `[]`

Keycloak · oceane read-only audit view

User accounts

Accounts 1–100 · 100 per page next page →

USERNAME	E-MAIL	REALM ROLE	ENABLED	MFA (OTP CONFIGURED)
a.allain			yes	yes
a.daniel		—	yes	yes
a.dubois			yes	yes
a.girard		—	yes	yes
a.guillou		—	yes	yes
a.henaff		—	yes	yes
a.jegou		-	yes	yes
a.kerbrat		dmin	yes	yes
a.kerbrat2		—	yes	yes
a.le-bihan		—	yes	yes
a.le-gall		—	yes	yes
a.martin		—	yes	yes
a.pennec		—	yes	yes
a.raoul		—	yes	yes
a.richard		—	yes	yes
b.gourmelen		—	yes	yes
b.le-corre		—	yes	yes
b.martin		—	yes	yes
b.olier		—	yes	yes
b.richard		—	yes	yes
b.robert		—	yes	yes
b.uguen		-	yes	yes
c.bonnet			yes	yes
c.briand		—	yes	yes
c.cloarec		—	yes	yes
c.derrien		—	yes	yes
c.dupont		—	yes	yes
c.fournier		—	yes	yes
c.garcia			yes	yes
c.girard		—	yes	yes
c.hamon			yes	yes
c.hamon2			yes	yes
c.itier		dmin	yes	yes
c.kerbrat		—	yes	yes
c.kerjean		—	yes	yes
c.kervella		—	yes	yes
c.kervella2		—	yes	yes
c.lagadec		—	yes	yes
c.lagadec2		—	yes	yes
c.lambert		—	yes	yes
c.le-goff		—	yes	yes
c.le-meur		—	yes	yes
c.pennec		—	yes	yes
c.roux		—	yes	yes
c.thepaut			yes	yes
c.uguen		—	yes	yes
d.dubois		—	yes	yes
d.lambert			yes	yes
d.le-corre			yes	yes

d.le-corre	—	yes	yes
d.raoul	—	yes	yes
d.uguen	—	yes	yes
d.vincent	—	yes	yes
e.floch	—	yes	yes
e.lagadec	—	yes	yes
e.le-gall	—	yes	yes
e.quillien	—	yes	yes
e.riou	—	yes	yes
e.tanguy	—	yes	yes
f.bernard	—	yes	yes
f.jegou	—	yes	yes
g.bonnet	—	yes	yes
g.briand	—	yes	yes
g.girard	—	yes	yes
g.laurent	—	yes	yes
g.le-corre	—	yes	yes
g.le-gall	—	yes	yes
g.le-goff	—	yes	yes
g.le-goff2	—	yes	yes
g.martin	—	yes	yes
g.martin2	—	yes	yes
g.michel	—	yes	yes
g.morvan	—	yes	yes
g.uguen	—	yes	yes
h.guillou	—	yes	yes
h.laurent	—	yes	yes
h.mercier	—	yes	yes
h.mercier2	—	yes	yes
h.petit	—	yes	yes
h.prigent	—	yes	yes
h.richard	—	yes	yes
h.salaun	—	yes	yes
h.thepaut	—	yes	yes
helpdesk	—	yes	yes
i.bertrand	—	yes	yes
i.david	—	yes	yes
i.hamon	—	yes	yes
i.jacq	—	yes	yes
i.jaouen	—	yes	yes
i.le-bihan	—	yes	yes
i.le-meur	—	yes	yes
i.martin	—	yes	yes
i.morvan	—	yes	yes
i.roux	—	yes	yes
i.salaun	—	yes	yes
i.simon	—	yes	yes
i.uguen	—	yes	yes
i.yvinec	—	yes	yes
j.bertrand	—	yes	yes
j.cloarec	—	yes	yes
j.garcia	—	yes	yes

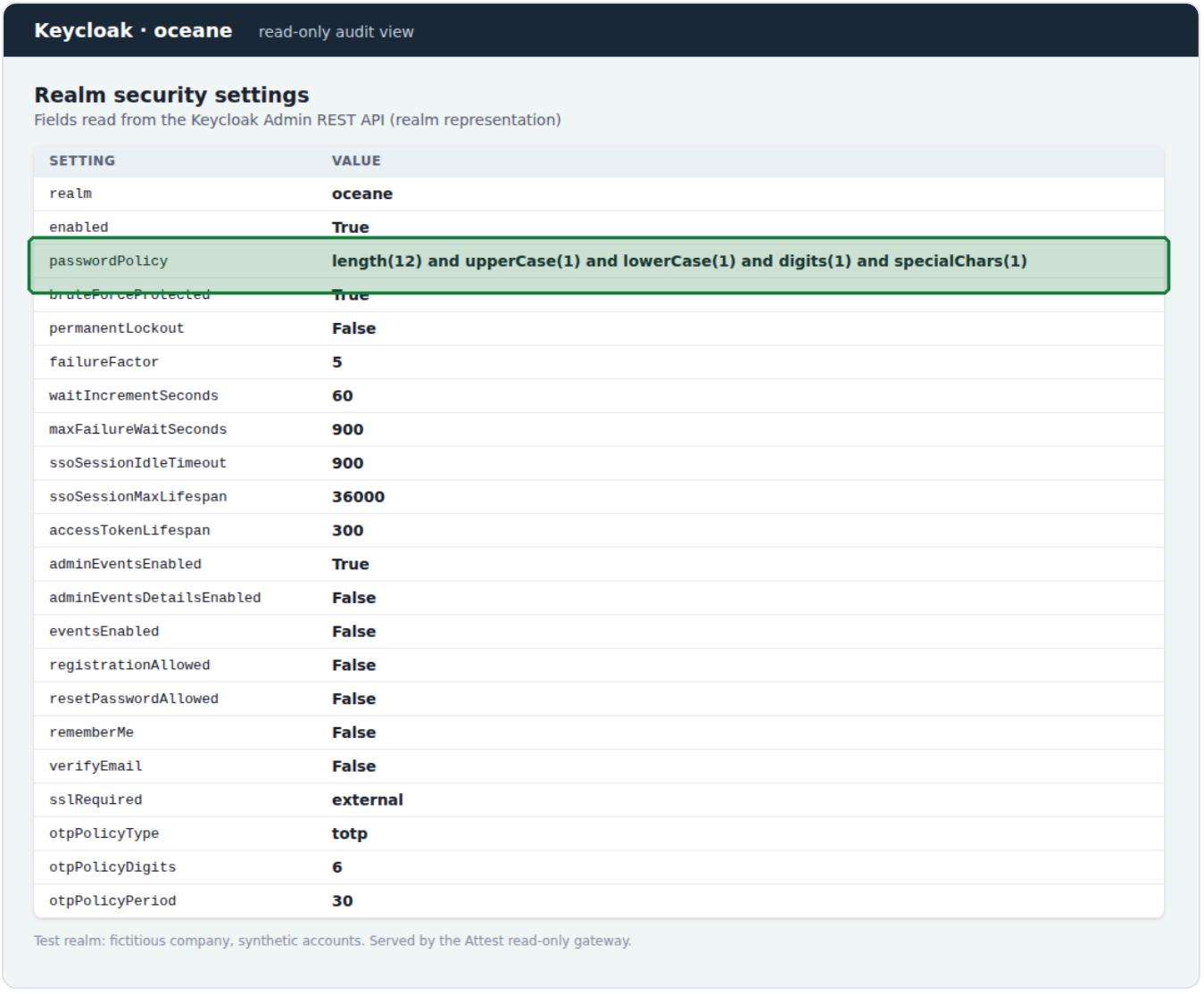
Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. All 100 visible user rows show MFA (OTP configured) as yes. · 100/100 sensitive data items masked (92 spotted by the AI, the rest by the deterministic safety net)
`2026-11-12 13:15:47 · SHA-256 5cac01b249ad6c11…`

PSI-4.3 Strong password policy with length and complexity

Medium · Compliant

Compliant control — The realm passwordPolicy requires minimum length of 12 characters with complexity requirements. · DORA 9(4)(d)
Observed: `length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)`



Keycloak · oceane read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**oceane**
enabled	**True**
passwordPolicy	**length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**5**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**900**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

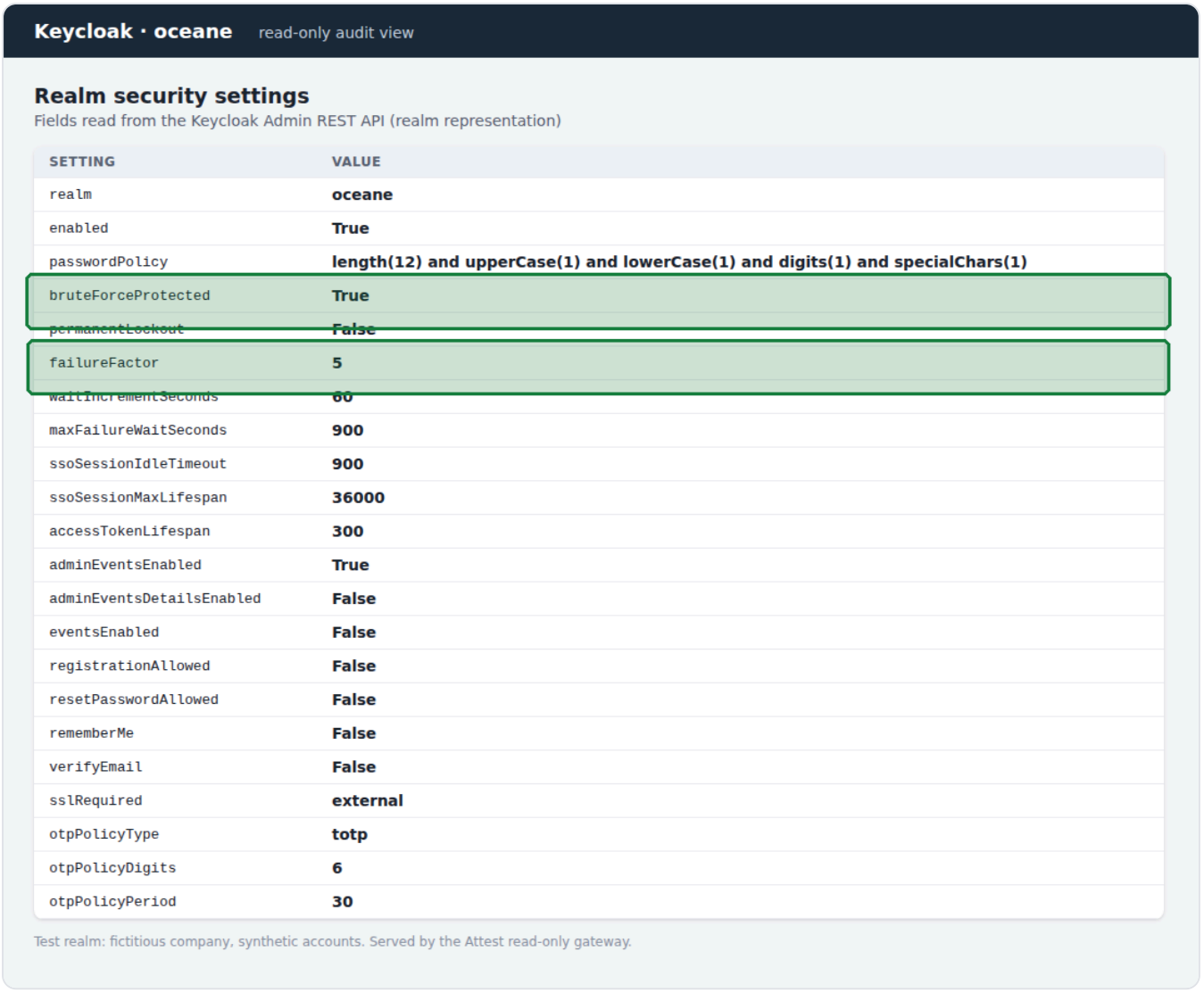
Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The passwordPolicy row shows length 12 with upper-case, lower-case, digit and special-character requirements.
`2026-11-12 13:13:36 · SHA-256 49ed6b4d14bcda3e…`

PSI-4.4 Account lockout after repeated login failures

Medium · Compliant

Compliant control — Account lockout on repeated login failures is enabled and triggers after at most 5 failures. · DORA 9(4)(c)
Observed: `{"bruteForceProtected": true, "failureFactor": 5}`

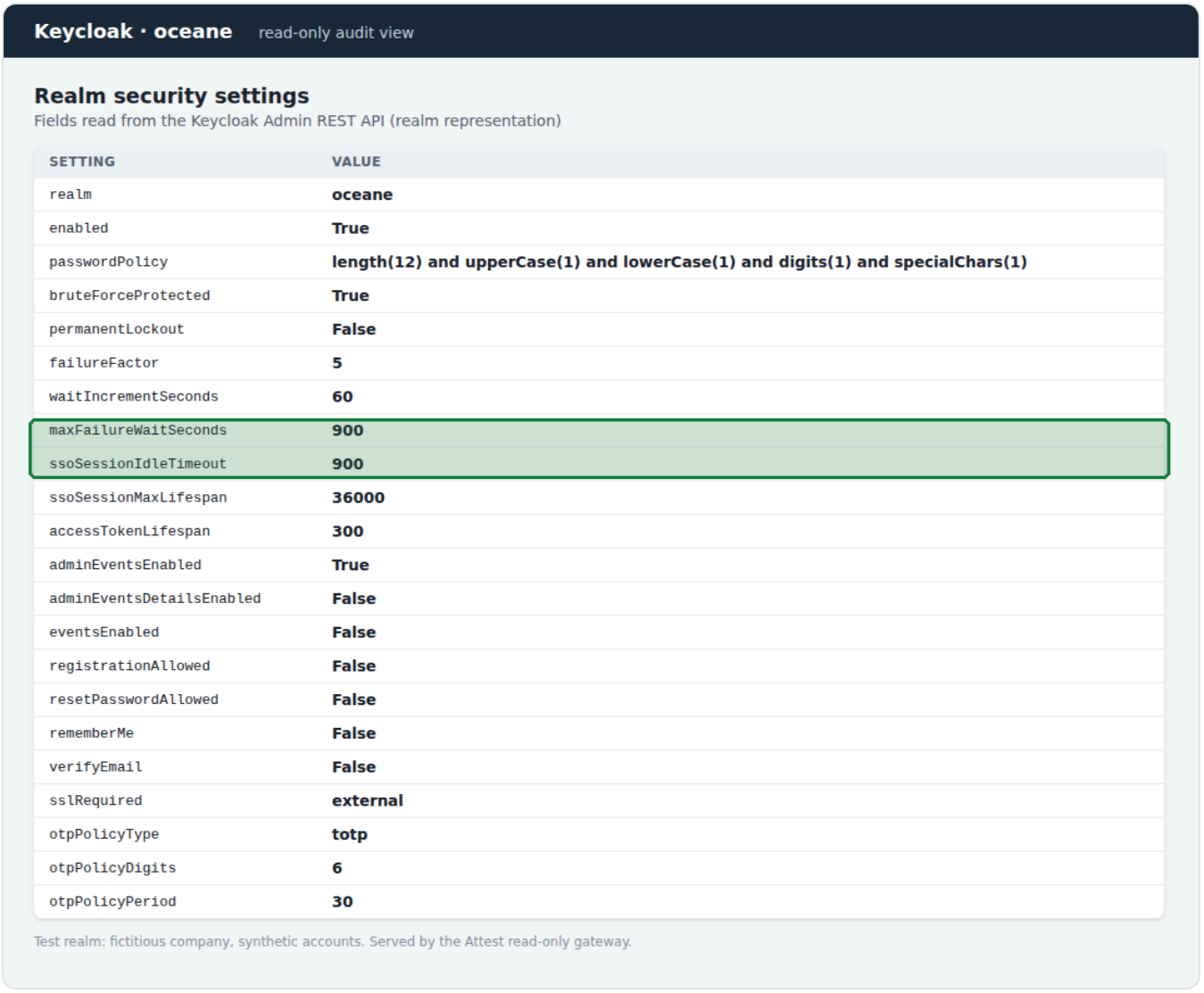


At testing — The screenshot corroborates the test. Screenshot shows bruteForceProtected is True and failureFactor is 5, matching the expected lockout threshold.
`2026-11-12 13:13:39 · SHA-256 77f319976b94ec4b…`

PSI-4.5 Idle session timeout limited to 15 minutes

Medium · Compliant

Compliant control — Idle SSO sessions expire after at most 15 minutes and idle timeout is not disabled. · DORA 9(4)(c)
Observed: `900`

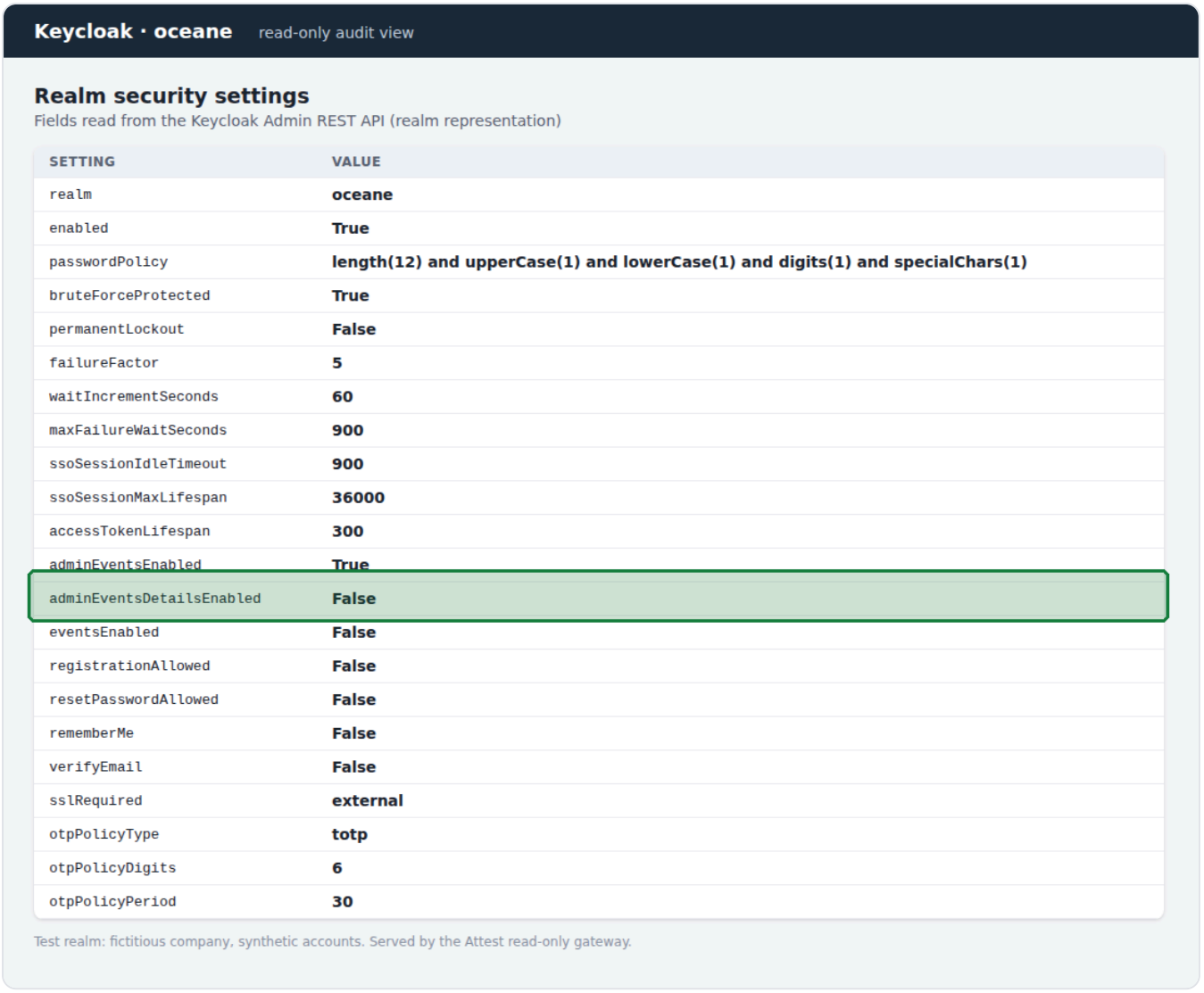


At testing — The screenshot corroborates the test. Screenshot shows ssoSessionIdleTimeout is 900 seconds, matching the passing test result.
`2026-11-12 13:13:51 · SHA-256 d0da4ac71b8540b0…`

PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are recorded as admin events in the realm. · RTS 12(2)(c)(i)
Observed: `true`



At testing — The screenshot corroborates the test. The screenshot shows adminEventsEnabled as True, matching the automated pass result.
`2026-11-12 13:14:01 · SHA-256 9ada2b69b53e823a…`

PSI-4.7 No generic or shared administrator accounts

High Compliant

Compliant control — No holder of the realm role admin is a generic or shared account, with each admin having a nominative username of form initiale.nom and a personal email. · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)
Observed: `["a.kerbrat", "c.itier", "j.opsomer", "k.morvan", "l.servien", "m.le-bihan-riou", "r.rootsaert", "t.teamson"]`



At testing — The screenshot corroborates the test. Screenshot shows eight admin accounts all with initiale.nom usernames and matching personal email addresses. · 8/8 sensitive data items masked

`2026-11-12 13:14:14 · SHA-256 ba93b9323c60d0ea…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · MFA enforced for privileged administrator accounts	c323691e8eb23997 · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · MFA enforced for users of critical system	cfb6a114374e16d2 · script library (reused)	Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy with length and complexity	6e6ff63181314ea6 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after repeated login failures	98ece24e4614a2d1 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Idle session timeout limited to 15 minutes	810b3ad6167c2214 · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	9169ba76dd0ecf4b · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared administrator accounts	d42aba1d639ac997 · script library (reused)	Compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-12 13:13:54	473f168ba6fbe17cbd476d089923f59bbe2af9bd1c882ec3a04b01cd5fa405ee
evidence/C2_before.png	C2 · At testing	2026-11-12 13:15:47	5cac01b249ad6c115469d81abc255fefe00e13e07b385f7085727967d4ead8bb
evidence/C3_before.png	C3 · At testing	2026-11-12 13:13:36	49ed6b4d14bcda3e63a50d9905595e1df21c8fc0d65520b40e8ccfac384bc66e
evidence/C4_before.png	C4 · At testing	2026-11-12 13:13:39	77f319976b94ec4ba0a70ce5b61be0be7ed6a21ac7ffa923ec4d6faf1e459022
evidence/C5_before.png	C5 · At testing	2026-11-12 13:13:51	d0da4ac71b8540b0659c1005bb933466909b0bc0d8a9638f44b8018ef1fa17f1
evidence/C6_before.png	C6 · At testing	2026-11-12 13:14:01	9ada2b69b53e823a6b97e18a3c331aa5a10b228a27e099a3b53006f3fb65cb5b
evidence/C7_before.png	C7 · At testing	2026-11-12 13:14:14	ba93b9323c60d0ea5bd4ee2fe13aaf5d048d25a1dd00897cc621fb17d1bff09f

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	7	15,642	21,108	0	0.1093

sam-3.1	19	0	0	19	price not published
Total					**0.1093**

Sensitive data (personal data and secrets) in evidence: 108/116 spotted by Muse Spark + SAM, 116/116 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`9db593d60cb01038a9d7050ec33380cd1d28e4f2efd23134c34e520048db8b0a`